Splitzy Backend API

Base URL: /api. JSON endpoints use Content-Type: application/json. Authentication failures return 401; invalid bodies and paths return 400 with field-level details; authorization failures return 403; missing resources return 404; throttling returns 429; unexpected server errors return a generic 500 without database or stack details.

Health

Method	Route	Auth	Behavior
GET	‘/health‘	Public	Liveness only; confirms the process responds.
GET	‘/ready‘	Public	Readiness check with a bounded database query; reports whether optional email credentials are configured.

Readiness does not expose connection strings or internal error details.

Authentication

Method	Route	Auth	Request
POST	‘/auth/register‘	Public, throttled	‘{ "name": "A User", "email": "a@example.com", "password": "at least 8 characters" }‘
POST	‘/auth/login‘	Public, throttled	‘{ "email": "a@example.com", "password": "..." }‘
POST	‘/auth/refresh‘	Refresh cookie, throttled	No body. Reads and rotates the HTTP-only ‘jwt‘ cookie; does not require an access token.
POST	‘/auth/logout‘	Refresh cookie if present	No body. Revocation is idempotent and the matching cookie is cleared.
POST	‘/auth/logout-all‘	Access token	No body. Revokes every refresh session and clears the current browser cookie.
GET	‘/auth/test‘	Access token	Returns the authenticated user payload.

Login and refresh responses return an access token in JSON. Send it on protected requests as Authorization: Bearer <accessToken>. Browser refresh requests must include credentials so the HTTP-only cookie is sent. The refresh cookie is scoped to /api/auth, HttpOnly, and SameSite=Strict by default. If deployment requires cross-site cookies, set COOKIE_SAME_SITE=none only over HTTPS; the API also checks allowed request origins for state-changing methods.

Authentication routes share a per-IP request limit of 20 requests per 15 minutes. When deployed behind a proxy, configure TRUST_PROXY to the exact trusted hop count; do not trust arbitrary forwarded headers.

Groups and members

Method	Route	Auth	Request / policy
POST	‘/groups‘	Access token	‘{ "name": "...", "description": "optional" }‘; creator becomes admin.
GET	‘/groups‘	Access token	Lists the caller?s active groups.
GET	‘/groups/:groupId‘	Access token, member	Returns group and member data.
PUT	‘/groups/:groupId‘	Admin	Partial ‘{ "name": "...", "description": "..." }‘; at least one field required.
DELETE	‘/groups/:groupId‘	Admin	Archives the group; all related history is retained.
POST	‘/groups/:groupId/members‘	Admin	‘{ "email": "existing-user@example.com" }‘.
DELETE	‘/groups/:groupId/members/:userId‘	Admin	Removes a member only when their active net balance is zero.

Group and user path parameters must be UUIDs. Archived groups are hidden from normal group, expense, balance, and settlement routes.

Expenses

All expense routes require an access token and active group membership.

Method	Route	Additional policy
POST	‘/groups/:groupId/expenses‘	Creates an expense from the request schema below. The payer and all split participant

s must be active group members.
GET ? ‘/groups/:groupId/expenses‘ ? Lists active expenses only.
PUT ? ‘/groups/:groupId/expenses/:expenseId‘ ? Payer or admin may update; settlement entries are not editable here.
DELETE ? ‘/groups/:groupId/expenses/:expenseId‘ ? Payer, split participant, or admin may archive the expense.
GET ? ‘/groups/:groupId/balances‘ ? Returns active net balances and simplified settlement suggestions.

Create/update request:

```
{
"description": "Dinner",
"amount": 42.75,
"category": "FOOD",
"splitType": "EQUAL",
"paidBy": "00000000-0000-4000-8000-000000000001",
"splits": [
{ "userId": "00000000-0000-4000-8000-000000000001" },
{ "userId": "00000000-0000-4000-8000-000000000002" }
]
}
```

Supported categories are GENERAL, FOOD, ACCOMMODATION, SHOPPING, TRANSPORT, and OTHER. SETTLEMENT is reserved for settlement routes. Supported split types are EQUAL, EXACT, PERCENTAGE, and SHARES. Each non-equal split row includes value (or legacy amount) for its amount, percentage, or share count. Participants must be distinct UUIDs. Amounts must be positive, finite, and have at most two decimal places; individual split amounts may be zero. Exact splits must add to the expense amount; percentages must total 100; shares must have a positive total. The server allocates rounding residuals deterministically in paise so the split total remains exact.

Settlements

Method ? Route ? Auth ? Request / policy
POST ? ‘/groups/:groupId/settlements‘ ? Access token, group member ? ‘{ "payeeId": "UUID", "amount": 25.00 }‘; caller is payer. Must be a different group member and the amount cannot exceed the caller?s current simplified debt to that payee.
GET ? ‘/groups/:groupId/settlements‘ ? Access token, group member ? Lists active settlements with payer/payee identiti es.
DELETE ? ‘/groups/:groupId/settlements/:settlementId‘ ? Access token, group member ? Payer, payee, or admin may archiv e the settlement.

Settlements are represented as an expense categorized SETTLEMENT and a single split; this is the canonical model used by balances. Creation serializes on the group ledger so concurrent payments cannot over-settle the same outstanding balance. A concurrent ledger change returns 409; refresh the balance before retrying.

CORS and validation

Set CLIENT_URL and optional comma-separated CLIENT_ORIGINS to exact browser origins. Credentialed requests are not combined with wildcard CORS. When a browser sends an Origin on a state-changing request, it must match the allowlist. Request bodies are limited to 100 KiB. Zod validation rejects unknown fields and returns details such as:

```
{
"error": "Validation failed.",
"details": [{ "field": "body.email", "message": "Invalid email" }]
}
```